

NAME: ARISHA FATIMA

DOMAIN: BLUE TEAM SOC (FEMALE)

GROUP: 01

TASK: SOC Detection and Response Playbook
- Open Redirect (Video Production Scenario)

1. Introduction:

An Open Redirect vulnerability occurs when a web application accepts untrusted input that specifies a target URL and redirects the user to that URL without proper domain validation.

In a “Video Production Organization”, external media asset portals and client review dashboards contain high-value proprietary assets. Attackers craft phishing links using the trusted organizational domain (e.g., <http://localhost:3000/redirect?to=http://evil-phishing-site.com>). When clients or employees click these links, they trust the primary domain name but are silently redirected to credential-harvesting phishing portals, risking asset leaks and account compromise.

2. Lab Setup and Attack Simulation:

Environment and Tools:

- **OS:** Kali Linux (VirtualBox).
- **Target Application:** OWASP Juice Shop running in Docker.
- **SIEM / Log Analysis Engine:** Splunk Enterprise (Free Tier).

Setup Steps:

- **Container Deployment:** Installed Docker and initiated the OWASP Juice Shop container mapping port 3000.

```

kali@kali:~$ sudo apt update
[sudo] password for kali:
Hit:1 http://kali.org/kali kali-rolling InRelease
1911 packages can be upgraded. Run 'apt list --upgradable' to see them.
The following packages were automatically installed and are no longer required:
libnss-curl python3-jinja2 python3-minimal python3-venv
libpython3.11-dev openjdk-21-jre-headless python3.11-venv
libltdl7 python3.11 libltdl-dev rpccsv-proto
libltdl-dev python3.11-dev rpccsv-proto
Use 'sudo apt autoremove' to remove them.

Installing:
docker.io

Installing dependencies:
containerd docker-buildx docker-cli runc tini-static

Suggested packages:
containernetworking-plugins debootstrap xfsprogs
docker-doc firewire zfs-fuse
btrfs-progs rootlesskit 2fsutils-linux

Recommended packages:
needrestart

Summary:
Upgrading: 0, Installing: 6, Removing: 0, Not Upgrading: 1911
Download size: 78.0 MB
Space needed: 331 MB / 7.317 MB available

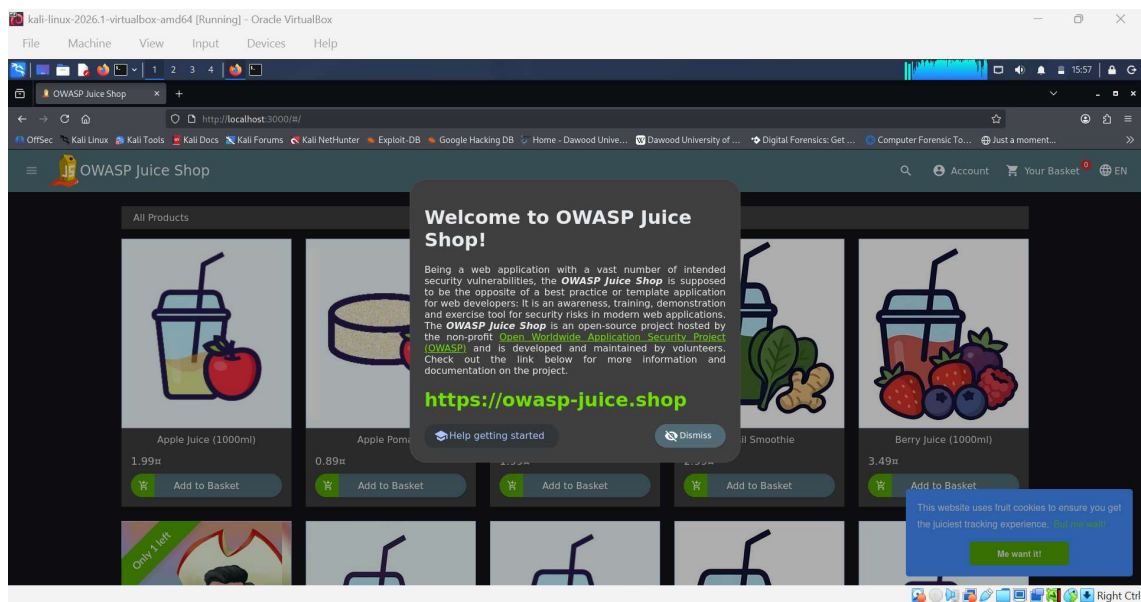
Get:1 http://kali.org/kali kali-rolling/main amd64 runc amd64 1.3.6ds1-1.6.780
Get:2 http://kali.org/kali kali-rolling/main amd64 docker-buildx amd64 0.21.5-1~14.3
Get:3 http://kali.org/kali kali-rolling/main amd64 containerd amd64 2.1.1-1~14.3
Get:4 http://kali.org/kali kali-rolling/main amd64 docker-cli amd64 28.5-2~14.3
Get:5 http://kali.org/kali kali-rolling/main amd64 tini-static amd64 0.19.0-6~14.3
Get:6 http://kali.org/kali kali-rolling/main amd64 docker.io amd64 28.5-2~14.3
Fetched 78.0 MB in 53s (1.472 kB/s)
Preconfiguring packages ...
Selecting previously unselected package runc.
Preparing to unpack .../runc-1.3.6ds1-1.amd64.deb.

```

```
kali-linux-2026.1-virtualbox-amd64 [Running] - Oracle VirtualBox
File Machine View Input Devices Help

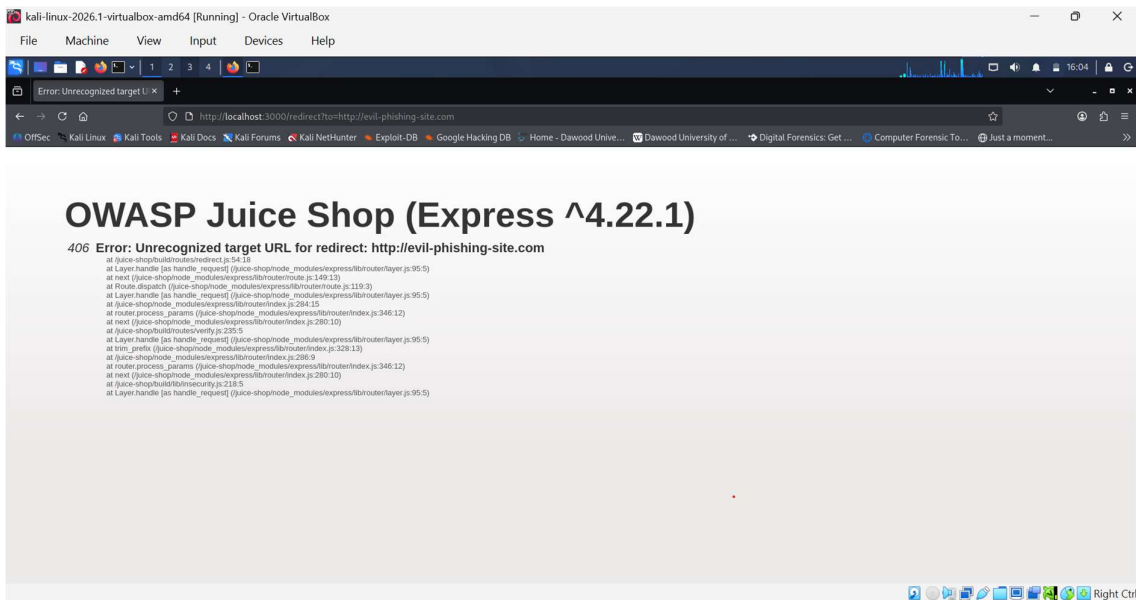
kali@kali:~$ sudo systemctl start docker
[sudo] password for kali:
kali@kali:~$ sudo docker run -d -p 3000:3000 --name juiceshop bkimminich/juice-shop
Unable to find image 'bkimminich/juice-shop:latest' locally
latest: Pulling from bkimminich/juice-shop
1eed391ea893: Pull complete
c372f21841df: Pull complete
9951567b4d35: Pull complete
990a082a91a2: Pull complete
d6b1b09ecac: Pull complete
2788928e5dbf: Pull complete
7c12899b777b: Pull complete
3214acff345c0: Pull complete
52638fc75a18: Pull complete
d054bf2d5177: Pull complete
83294fae116: Pull complete
ebddc55facdc: Pull complete
b0fd77e50f6: Pull complete
2d4d7ad6272: Pull complete
cf593222899a: Pull complete
bd8962c29291: Pull complete
cac2a8d193cb: Pull complete
d0899fd3bee: Pull complete
7cc7b0fd08cf: Pull complete
8224d91da7b0: Pull complete
1a8be5502d92: Pull complete
2ba734cb9f70: Pull complete
37c0829f1adc: Pull complete
467afe997cab: Pull complete
Digest: sha256:73c33bf442e8337b3ea3d98c7e85308854701ebdfc4cc39768f36b7343
Status: Downloaded newer image for bkimminich/juice-shop:latest
b91e44abc8be40f2012887df5a9612c00c39743e3f1ca86a52792d8ef2b72bc
```

- **Service Verification:** Accessed the application homepage at <http://localhost:3000> to confirm lab connectivity.

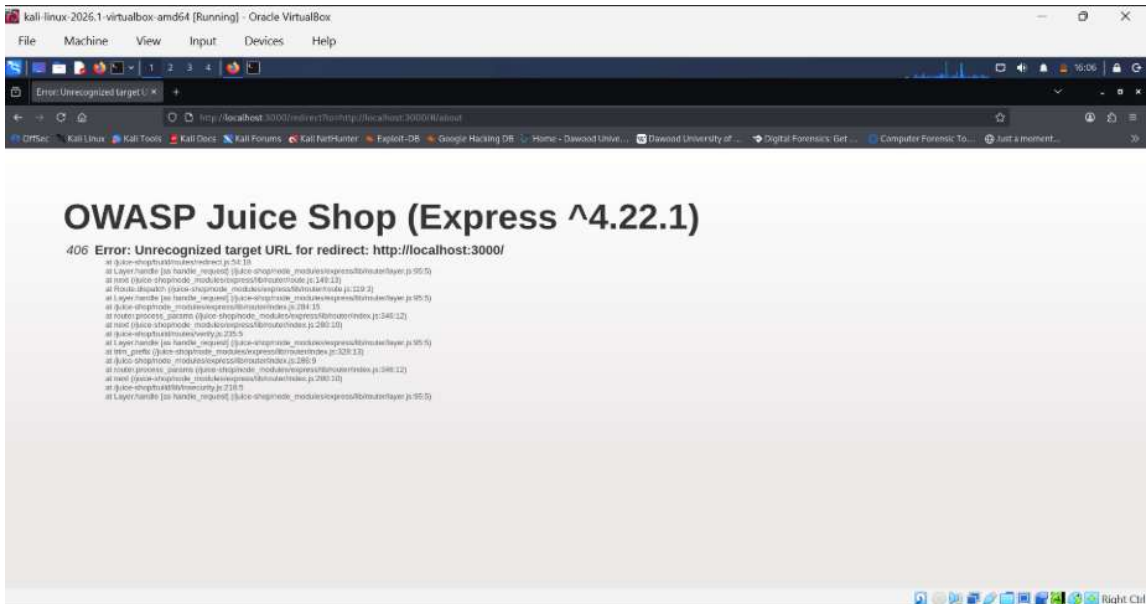


Traffic Generation:

- **Attack Payload (Malicious Target):** <http://localhost:3000/redirect?to=http://evil-phishing-site.com>



- **Benign Baseline (Whitelisted Target):**
<http://localhost:3000/redirect?to=https://github.com/bkimminich/juice-shop>



3. Log Ingestion and Baseline Analysis:

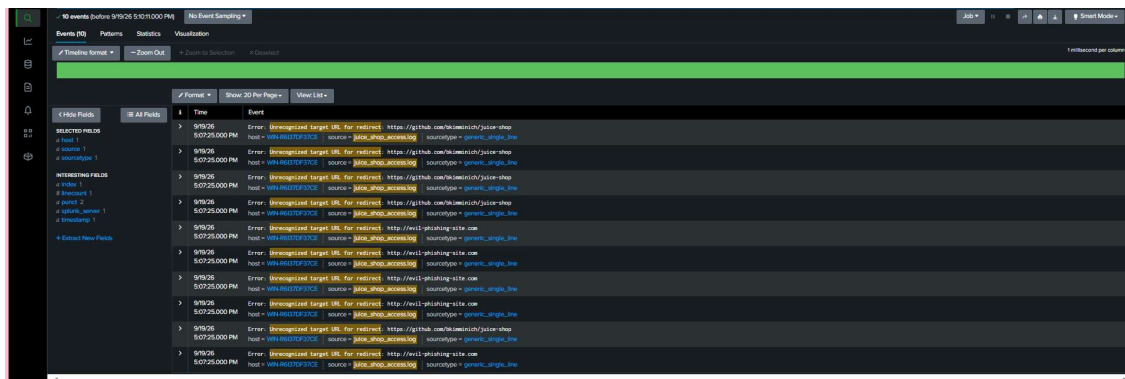
1. **Log Extraction:** Generated application logs were filtered for redirect events and saved to juice_shop_access.log using the following terminal command:

```
sudo docker logs juiceshop 2>&1 | grep -iE "redirect|Unrecognized" > juice_shop_access.log
```

```
(kali@kali)-[~]
$ sudo docker logs juiceshop 2>&1 | grep -iE "redirect|Unrecognized" > juice_shop_access.log
[sudo] password for kali:

(kali@kali)-[~]
$ cat juice_shop_access.log
Error: Unrecognized target URL for redirect: http://evil-phishing-site.com
at /juice-shop/build/routes/redirect.js:54:18
Error: Unrecognized target URL for redirect: https://github.com/bkimminich/juice-shop
at /juice-shop/build/routes/redirect.js:54:18
Error: Unrecognized target URL for redirect: http://evil-phishing-site.com
at /juice-shop/build/routes/redirect.js:54:18
Error: Unrecognized target URL for redirect: http://evil-phishing-site.com
at /juice-shop/build/routes/redirect.js:54:18
Error: Unrecognized target URL for redirect: http://evil-phishing-site.com
at /juice-shop/build/routes/redirect.js:54:18
Error: Unrecognized target URL for redirect: http://evil-phishing-site.com
at /juice-shop/build/routes/redirect.js:54:18
Error: Unrecognized target URL for redirect: https://github.com/bkimminich/juice-shop
at /juice-shop/build/routes/redirect.js:54:18
Error: Unrecognized target URL for redirect: https://github.com/bkimminich/juice-shop
at /juice-shop/build/routes/redirect.js:54:18
Error: Unrecognized target URL for redirect: https://github.com/bkimminich/juice-shop
at /juice-shop/build/routes/redirect.js:54:18
Error: Unrecognized target URL for redirect: https://github.com/bkimminich/juice-shop
at /juice-shop/build/routes/redirect.js:54:18
```

2. **Splunk Ingestion:** Imported juice_shop_access.log into Splunk Enterprise.
 - **Unfiltered Baseline:** Searching source="juice_shop_access.log" returned 10 events containing both benign (github.com) and attack (evil-phishing-site.com) attempts.

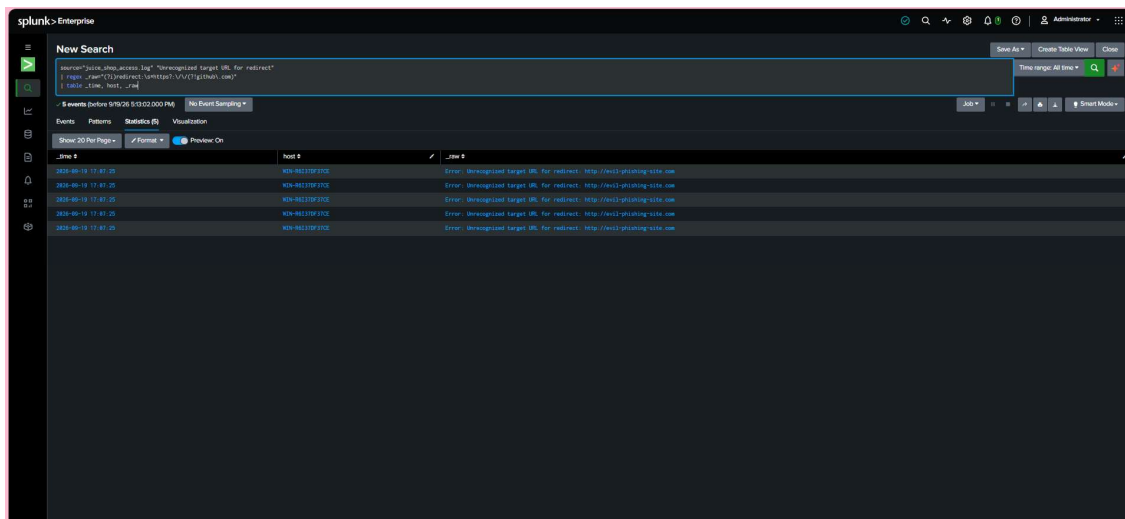


4. Detection Rule Engineering and Rule Testing:

- **Splunk Search Processing Language (SPL) Query:**
To isolate untrusted redirection targets from legitimate baseline traffic, the following tuned SPL regex query was executed:

```
source="juice_shop_access.log" "Unrecognized target URL for redirect"
| regex _raw="(?!i)redirect:\s*https?:\V\V(?!(github\.com))"
| table _time, _raw
```

- **Validation Results (Rule Performance):**
 - **Total Ingested Events:** 10
 - **Filtered Alert Output:** 5 events
 - **Outcome:** The rule successfully flagged 100% of malicious requests (evil-phishing-site.com) while ignoring all benign whitelisted navigation (github.com), resulting in zero false positives.



5. Tier-1 SOC Alert-Triage Checklist:

When an Open Redirect alert fires in the SIEM, the analyst must complete the following steps sequentially:

- **Extract Indicators:** Parse the source IP, destination domain parameter, and requested asset URI path from `_raw` log details.
- **Verify HTTP Response Code:** Confirm whether the response resulted in a successful redirect (301/302) or a server rejection (406/400).
- **Domain Threat Intelligence:** Submit the extracted target domain (evil-phishing-site.com) to VirusTotal and AbuseIPDB to evaluate domain age and reputation score.
- **User Context Correlation:** Search network access logs to determine if any internal employee or client account executed authentication requests immediately following the redirect timestamp.
- **Classification & Escalation:**
 - **False Positive:** Close ticket if target domain is an approved partner domain (and update SPL whitelist).
 - **True Positive:** Escalate to Incident Response Lead if the destination domain is untrusted or malicious.

6. Incident Response Playbook (Video Production Scenario):

Phase 1: Containment

1. **Network Mitigation:** Apply immediate block rules on the Web Application Firewall (WAF) and Perimeter Firewall for the destination domain/IP.
2. **DNS Sinkholing:** Update internal DNS resolution to sinkhole the malicious target URL across corporate networks.
3. **Session Invalidation:** Force session reset for any user identified clicking the malicious link within the active timeframe.

Phase 2: Notification and Communication

1. Notify SOC Lead and Application Security Lead.
2. If external client review portals were targeted, notify the Client Asset Security Coordinator to distribute phishing advisories.

Phase 3: Remediation and Hardening

1. **Source Code Patch:** Require developers to remove absolute URL redirection parameters and enforce relative path redirects (redirect=/dashboard).
2. **Server-Side Allowlisting:** Implement strict server-side domain allowlisting for all required external third-party integrations.

7. Detection Blind Spots and Known Limitations:

1. **Obfuscation and Encoding:** Double URL encoding (%252F) or Base64 encoded payload strings (aHR0cDovL2V2aWwuY29t) bypass standard plain-text regex queries.
2. **Client-Side DOM Redirection:** Client-side JavaScript redirects (window.location.href) executed entirely within browser DOM environments do not generate 302 HTTP response entries on web server logs.
3. **IP Representation Evasion:** Use of alternate IP representations (Hexadecimal, Octal, or Decimal formats) can evade standard hostname pattern matching.

8. Conclusion:

In this task, we designed a complete SOC monitoring and response framework against the Open Redirect vulnerability, framed around a real-world Video Production organization scenario. Using OWASP Juice Shop and Docker to generate real attack and benign traffic, we tested detection rules in Splunk SIEM, tuned out false positives, and successfully established an actionable Triage Checklist and Incident Response Playbook.